SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I T Siva Nalayana (192472027) *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

1. Testing Beyond the Autorized Scope.

A. No, I would not Exploit the vulnerability without the obtaining additional authorization from the Company. Ethical hacking must be performed within the argeed scope and with proper permission.

Reason :-

1. Lack of authorization :- The discovered system is not included in the approved testing scope. Testing it futher could be unauthorized access.

2. Risk of damage :- Exploiting the vulnerability may cause dataloss, service disruption, or security problem.

3. professional ethics :- An Ethical hacker must act honestly, Responsibly and legally.

4. Confidentiality :- Any Sensitive information discovered must be protected and not disclosed to unauthorized people.

Steps I would take :-

* Stop testing the vulnerable system immediately.
* Record the vulnerability details without Exploiting it.
* Inform the Company's authorized Contact about the potential risk.

* Request written permission and an updated scope Before performing further tests.

* If the vulnerability presents an immediate the danger, recommend appropriate protective measures.

Conclusion :- A vulnerability should never be exploited beyond the agreed scope merely to demonstrate its impact.

2. SQL injection in a production Database

A :- When database contain real customer financial information, I would prioritize data protection and bussiness continuity. I would not perform destructive SQL injection tests or access unnecessary customer services.

How I would proceed safely :-

1) Confirm authorization :- Verify that SQL injection testing is explicitly included in the written scope

2) use a controlled approch :- Begin with haemless, non destructive tests to confirm the vulnerability.

3) Avoid sensitive data :- Do not Retrieve, modify or delete real customer financial records.

4. uses a test Environmental :- whenever possible, Reproduce the vulnerability in a staging environment Containing Synthetic data.

5. Monitor the system :- coordinate with client's technical team to identify unusal databases activity.

6. Report the finding :- Document the vulnerability, its potential impact, and Recommended Remediation.

precautions Before testing :-

* Obtain written authorization and clearly define the testing scope
* Identify production systems and sensitive data.
* Establish testing limits and prohibited activities.
* Agree on Emergency Contacts and a Stop-testing Procedurce.
* Create verified backups and Recovery plan.
* Define data-handling, confidentiality and the Reporting Requirements.
* Schedule high risk tests dueing an approved maintaienance when appropriate.

Conclusion :- Safe penetration testing should be demonstrate the existence, and the potential impact of SQL injection while minimizing risk to real Customer data.

3. Accidential Denial-of-Service @cuing a penetration test.

A:- A DOS Condition occur when a System becomes Unavailable or difficult to access becauses its Resources are over whelmed or disrupted

Preventive measures :-

1) Define testing Boundaries :- Clearly identify system, methods, and activites permitted during the Engagement.

2) Assess Risks :- Identify tests that could affect server performance or availability.

3) Avoid aggressive testing :- Do not perform high-volume Requests or stress tests against production system without Explicit authorization.

4) ues a test Environment :- Perform potentially disruptive Experiments on a Separate system whenever possible.

5. Set monitoring Controls :- Monitor Server Performance, Response time, and error rates during testing.

6. Establish Stop procedure :- Agree On clear conditions for immediately stopping the assessment.

Responsibilites after the outage :-

1) Stop testing immediately :- Terminate the activity Responsible for the disruption.

2) Notify the client :- Inform the authorized Contact and incident-Response team without delay.

3) Support Recovery :- cooperate with the client's IT team to Restore the service safely.

4) Preserve evidence :- Record the timelines, actions performed, observed errors, and system Responses.

5) Avoid further Changes :- Do not attempt unauthorized Repairs or modifications.

6) Conduct a root-Cause Analysis :- Identify why the test caused the outage and how Recurrence Can be prevented

Conclusion:- Ethical hackers must priotize service availability and client safety. If an outage occurs they should stop the activity, communicate transparently assists.

4. Testing without Informing the IT Department.

A:- This type of assessment Resembles a convert Penetration test or red-team Execrise. The purpose is to Evaluate whether an organization's security team can detect and Respond to realistic attacks.

Ethical and pratical Risks:-

1) Incident misinterpretation:- The IT team may mistake authorized testing for a real cyber attack.

2) Service disruption:- Defensive actions taken by the IT team may interrupt bussiness operations.

3) Legal concerns:- Testing without appropriate the written authorization may result in authorized access allegations.

4) Data Exposure:- Testing may unintentionaly Expose confidential information

5. Incident - Response conflicts :- The IT team might block the test, isolate systems, or initiate emergency procedures.

6. Accountability issues :- without clear agreements, Responsibility for unexpected damage may become disputed.

How I would structure the Engagement :-

1) Obtain written authorization :- Ensure the that an authorized company Representative approves the Execresie.

2) Define the scope :- Identify permitted system, testing methods, time limits and prohibited activites.

3) Establish an Emergency contact :- Designate a trusted Person who can stop the Execresie if neccessary

4) Define Rules a Engagement :- Specify acceptable actions, risk limits, data-handling Requirements, and incident procedures.

5. Agree on a deconflication process:- Establish how the Exercise will be stopped if it creates unacceptable Risk.

6. set clear objectives :- Define what detection and Response capabilities will be Evaluated

Conclusion :-

A covert Security assessment can help Evaluate Real-world detection capabilities, but secrecy must not Replace authorization, written permission, clear rules of Engagement, Emergency Procedures and accountability are essential.

5. Red-Team Exercise vs. Vulnerability Assessment for a Bank.

Ans:- Both Security Evaluation methods, but they have different objectives.

A Vulnerability assessment identifies and the prioritizes security weakness, while a red-team Exercise Evaluates whether an organisation's Security Controls and personnel can prevent detect.

A. Vulnerability Assessment

Suppose a bank wants to identify weakness in its online Banking systems, internal network, and office security systems.

Approach :-

1) Identify the system included in the assessment

2) Scan authorized system for known vulnerabilites

3) Review software versions, security configueations, and acess controls.

4) Examine identified weakness to deteemine their seveeity.

5) Rank vulnerabilities acording to risk.

Ethical Consideeations :-

* Obtain written authorization.

* Avoid accessing Real customer financial data unnecessaeily.

* DO not modify or delete banking Records.

* Minimize disruption to Banking senices.

* PROtect assessment Results and Confidential information

Rules of Engagement :- The agreement should define the Systems to be assessed, permitted scanning methods, testing Schedule, Reporting requirements and Restrictions or intrusive testing.

Outcome :- The Bank Receives a vulnerability Report Containing identified weakness, Severity Ratings and Evidence.

B. Red-Team Execrise :- Suppose the same Bank wants to determine whether an attacker could bypass physical and digital Security Controls to Reach a sensitive Banking System.

Approach :-

* Develop an approved attack Scenario based on Realistic threats.
* Assess the Bank's Externals digital Security within the aggreed Scope
* Test approved physical Security Controls using Authorized methods
* Evaluate whether security moinitoring detects the simulated activities.

Ethical considerations:-

* obtain Explicit written authorization form the appropriate Bank authorities.

* Never use real character transactions or steal customer funds.

* Avoid Exposing Confidential Banking information.

* protect all evidence and the disclose findings only to authorized Recipients.

Rules of Enagagement:-

The aggreement should specify the authorized attacks scenarios, physical locations, digital systems, testing dates, permitted techniques, prohibited actions, Emergency contacts.

Outcomes:-

The Bank Receives a Report describing which simulate attacks paths succeeded or failed, what the security team detected, how it responded and which the defensive improvements are required.

Conclusion:- Ethical hacking is authorized pratice of identifying security weakness to improve an organisations cyber security. Ethical hackers must be! must follow the agreed scope, protect confidential information, mimine operational risks, communicate incidents immediately, and Report vulnerabilities Responsibly.